ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

Siemens Desigo CC (Building Management Platform) · Component type: **Software Application (SAR) - BMS management** · Target SL = SL 3

Where to work	Desigo CC **System Management** › **Users / User Groups / Scopes** (application rights, AD integration); **Audit Trail**; certificate management (HTTPS / **BACnet/SC**); project & distributed-system security; Flex/Installed/Web client config. Underlying **Windows Server** hardening applies.
Interfaces / ports	BMS management platform; BACnet/IP + **BACnet Secure Connect (BACnet/SC)**, OPC UA, Modbus to field; HTTPS Flex/Web clients (443); SQL Server (history). Client/server or standalone.
Notes	SAR (software application) — Siemens BMS management platform. Platform controls are inherited from the Windows host cheat sheet; field controllers (PXC/Apogee) are covered by their own sheets.
How to read	Read-only: review Desigo CC users/scopes, audit, certificates, and the hosting Windows policy. Native how-to + external-tool validation + pass. Scans authorized; exploit/fuzz only in an isolated environment.

Project capture & evidence handling - capture the full application backup + exports

Do this BEFORE working the checklist - screenshots of the config and programming screens are not enough on their own. Capture the application's own backup and exports so nothing is missed:
1. Take the native full backup / export first (read-only, before anything): the Desigo CC project backup (System Management Console > Project > Backup), the user/role and scope configuration, and the system / audit logs.
2. Export the security config: users / roles / permissions, authentication / IdP settings, audit configuration, and TLS / certificate settings - as files and screenshots.
3. Collect the logs: application, service / wrapper, audit and event logs (exports), plus running-threads / diagnostics dumps where the product provides them.
4. Capture identity & version: product edition + version / patch level, installed modules / components, and the host OS / runtime (JRE / .NET) - screenshot the About / version screen.
5. Name + protect (keep everything): `<site>_<zone>_<assetTag>_<product>_<version>_<YYYYMMDD-HHMM>_<initials>` with the native backup extension + the exports; SHA-256 hash the backup; store **only** on the encrypted evidence share; the backup usually contains secrets / credentials - **never** email it in cleartext and follow the project retention / classification policy. Do not save admin passwords in tool profiles.
6. Then analyze offsite against the product-specific checklist, the product manuals, vendor research and experience; fill in the tool and auto-generate the report - and remember the manual fields the tool can't auto-write: the **executive-summary narrative**, the **overall assurance level + justification**, and the **punch-list**.

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 1.1	Human user identification & auth	Confirm every operator/engineer authenticates to Desigo CC (local or **Windows/AD** accounts) before any client/Web access; no anonymous/auto-login. **Ext. tools:** System Management (Users) review.	All access authenticated; no anonymous use.	
SR/CR 1.2	Software process & device identification & authentication	Confirm devices and software processes are identified/authenticated to the component. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Software process & device identification & authentication verified individually.	
SR/CR 1.3	Account management	Manage users, **user groups**, and **scopes** (application rights + object/discipline scope): create/modify/disable, least privilege (monitor vs operate vs engineer vs admin); no shared logins. **Ext. tools:** System Management (groups/scopes) review.	Accounts managed; least-privilege scopes; no shared logins.	
SR/CR 1.4	Identifier management	Confirm unique user identifiers (local/AD) and unique server/site identity; BACnet device instances unique; no reuse. **Ext. tools:** User + BACnet device-ID review.	Unique user and device identifiers; no reuse.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 1.5	Authenticator management	Enforce password policy (Desigo CC password rules or delegated AD policy): length/complexity/expiry; change defaults; manage lifecycle. **Ext. tools:** Password-policy review (Desigo CC / AD).	Strong, managed authenticators; no defaults.	
SR 1.6	Wireless Access Management	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 1.7	Strength of password-based authentication	Confirm the password-strength policy (length/complexity/lifetime) meets SL-3. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.5** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of password-based authentication verified individually.	
SR/CR 1.8	PKI certificates	Confirm certificates for HTTPS clients, BACnet/SC, and OPC UA are CA-issued, valid, and not default self-signed; manage the trust store. **Ext. tools:** Browser/openssl (443); BACnet/SC + OPC UA cert review.	CA-issued, valid certificates; defaults replaced.	
SR/CR 1.9	Strength of public key auth	Confirm TLS 1.2/1.3 with strong ciphers on Web/BACnet/SC/OPC UA; no weak/expired certs. **Ext. tools:** testssl.sh; BACnet/SC + OPC UA policy review.	Strong certificate/TLS crypto; weak protocols disabled.	
SR/CR 1.10	Authenticator feedback	Confirm the Desigo CC and Web/Flex logon dialogs mask password entry (no cleartext echo). **Ext. tools:** Visual verification.	Authenticators obscured during entry.	
SR/CR 1.11	Unsuccessful login attempts	Confirm lockout/throttling on repeated failed logins and that failures are recorded in the audit trail / Windows security log. **Ext. tools:** Lockout policy; audit-trail / Event Viewer.	Failed logins locked out and logged.	
SR/CR 1.12	System use notification	Confirm the approved use-notification banner appears before access (Windows logon banner on the server; Web login notice where supported). **Ext. tools:** GPO logon banner; Web login review.	Approved use notification presented before access.	
SR 1.13	Access via untrusted networks	Confirm Web/Flex clients are reachable only from trusted zones or via a reverse proxy/VPN in a DMZ; deny direct access from untrusted networks. **Ext. tools:** Nmap (untrusted side); firewall/DMZ review.	Access from untrusted networks denied/brokered; remote via VPN/DMZ.	

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 2.1	Authorization enforcement	Confirm **scopes + application rights** enforce what each group may view/command/configure; unauthorized commands (e.g. override, program) denied. **Ext. tools:** Scope/right review; attempt unauthorized command (isolated).	Least-privilege authorization enforced.	
SR/CR 2.2	Wireless Use Control	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR 2.3	Use control for portable/mobile devices	Control removable media on the server (Windows device control); no unmanaged media loads projects/updates. **Ext. tools:** GPO device-control review (see Windows sheet).	Removable-media use controlled on the server.	
SR/SAR 2.4	Mobile code	Restrict active/mobile code: Web/Flex client content controlled, project scripting reviewed/limited, app allow-listing (AppLocker/WDAC) on the host; no untrusted code executes. **Ext. tools:** Project/script review; AppLocker/WDAC policy.	Only trusted project code runs; untrusted mobile code blocked.	SAR-specific.
SR/CR 2.5	Session lock	Confirm client auto-logoff on inactivity and OS screen-lock; re-authentication required to resume. **Ext. tools:** Auto-logoff config; GPO screen-lock.	Sessions lock/log off on inactivity; re-auth required.	
SR/CR 2.6	Remote session termination	Confirm Web/Flex/RDP sessions time out and can be terminated by admin; clients logged off centrally. **Ext. tools:** Timeout config; session review.	Remote sessions time out and are terminable on demand.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 2.7	Concurrent session control	Confirm concurrent client/Web sessions are limited by license/policy; no shared concurrent privileged logins. **Ext. tools:** Client/Web session review.	Concurrent sessions limited/monitored.	
SR/CR 2.8	Auditable events	Confirm the **Audit Trail** records operator commands, config changes, and logons with the user identity; forward to SIEM; actions attributable. **Ext. tools:** Audit Trail config; SIEM forwarding.	Operator/config actions audited and attributable.	
SR/CR 2.9	Audit storage capacity	Confirm audit/history storage (SQL) is sized, backed up, and offloaded so records are retained; forward security events to the SIEM. **Ext. tools:** SQL/history sizing; SIEM retention.	Audit/history storage sized and retained.	
SR/CR 2.10	Response to audit processing failures	Confirm defined behavior on audit/history failure (alarm on stop, SIEM alert on forwarding loss); records not silently lost. **Ext. tools:** History alarms; SIEM agent-health alert.	Defined response to audit failure; alerting on loss.	
SR/CR 2.11	Timestamps	Confirm server, clients, and BACnet field time are synchronized (NTP/AD, BACnet time sync) so audit/alarm timestamps are accurate and correlate. **Ext. tools:** w32tm / NTP; BACnet time-sync review.	Reliable, synchronized timestamps.	
SR/CR 2.12	Non-repudiation	Confirm actions are attributable to a specific user (non-repudiation). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Non-repudiation verified individually.	

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 3.1	Communication integrity	Legacy **BACnet/IP is unprotected** (no encryption). Where supported, enable **BACnet/SC** (certificate/X.509-based TLS; Desigo CC profiles B-AWS/B-ALWS/B-ACCWS/B-XAWS) and OPC UA sign+encrypt, plus HTTPS to clients; contain any remaining cleartext BACnet/IP inside the firewalled zone / VPN. **Ext. tools:** Wireshark (BACnet/SC vs cleartext BACnet/IP); OPC UA policy check.	BACnet/SC (certificate TLS) where supported; cleartext BACnet contained to the zone.	
SR/SAR 3.2	Protection from malicious code (component)	Confirm the host runs endpoint protection per the Siemens compatibility guidance, app allow-listing, and project integrity controls so the BMS application resists malicious code. **Ext. tools:** AV/allow-list review; project integrity check.	Application protected from malicious code.	SAR-specific.
SR/CR 3.3	Security functionality verification	After change, re-verify users/scopes, audit, certificates, and host hardening (STIG/CIS) against the baseline. **Ext. tools:** SCAP/STIG host scan; Desigo CC config compare.	Security settings match the baseline after change.	
SR/CR 3.4	Software & information integrity	Confirm project integrity: project access protection, change control via the audit trail, controlled distribution to Flex servers so unauthorized changes are prevented/detected. **Ext. tools:** Project protection; audit-trail change history.	Project integrity protected; unauthorized change prevented/detected.	
SR/CR 3.5	Input validation	Confirm exposed services (Web, BACnet/SC, OPC UA) tolerate malformed input without crashing; keep patched to current Siemens updates; fuzz only in a lab. **Ext. tools:** Siemens ProductCERT/patch review; fuzz (ISOLATED).	Patched against input-validation CVEs; no crash on malformed input.	Do NOT fuzz production.
SR/CR 3.6	Deterministic Output	**N/A.** Device does not drive process outputs; deterministic/fail-safe output is not applicable.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 3.7	Error handling	Confirm graceful handling of faults/comm loss (distributed-system failover where used, no info leakage in errors, clean recovery). **Ext. tools:** Failover test (lab); error-handling review.	Graceful error handling; no sensitive info leak.	
SR/CR 3.8	Session integrity	Confirm client/BACnet/SC/OPC UA sessions are integrity-protected (TLS), replay-resistant. **Ext. tools:** Wireshark (TLS session inspection).	Sessions integrity-protected against replay/hijack.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 3.9	Protection of audit information	Protect the audit trail and history: restricted DB access, forwarded to a write-once SIEM, so records cannot be altered/deleted by unauthorized users. **Ext. tools:** SQL permission review; SIEM immutability.	Audit records protected from unauthorized read/modify/delete.	

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 4.1	Information confidentiality	Confirm information confidentiality — sensitive data is protected in transit and at rest. **Steps:** for this product this is assessed with the same evidence as **SR/CR 3.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Information confidentiality verified individually.	
SR/CR 4.2	Information persistence	On decommission/reuse, remove the Desigo CC project, history, credentials, and certificates; sanitize host storage so data is not recoverable. **Ext. tools:** Project/history removal; host sanitize (see Windows sheet).	Sensitive project/history data purged on decommission.	
SR/CR 4.3	Use of cryptography	Confirm modern crypto for HTTPS/BACnet/SC/OPC UA (TLS 1.2/1.3, strong suites) and that stored credentials/keys are protected; disable weak protocols. **Ext. tools:** testssl.sh; crypto config review.	Modern crypto in use; weak protocols disabled.	

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 5.1	Network segmentation	Per the Desigo CC Cybersecurity Guidelines, place the BMS in a **Protected Zone** with true **Zone Boundary Protection** — a firewall is required; **a separate VLAN alone does NOT meet ZBP**. Web clients via DMZ/reverse proxy; disable FTP (use Secure download); only required flows cross. **Ext. tools:** Nmap by zone; firewall rule review (confirm ZBP, not just VLAN).	BMS in a firewalled Protected Zone (VLAN alone insufficient); only required flows cross.	
SR 5.2	Zone boundary protection	Confirm zone-boundary protection — only required flows cross the boundary (system SR / network device). **Steps:** for this product this is assessed with the same evidence as **SR/CR 5.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Zone boundary protection verified individually.	
SR 5.3	General-purpose person-to-person comms restrictions	Confirm the server/clients are single-purpose: email/IM/arbitrary web removed or blocked, app allow-listing + egress filtering. **Ext. tools:** App inventory; egress/proxy review.	No general-purpose person-to-person comms on the BMS station.	
SR 5.4	Application partitioning	Confirm role separation (engineering vs operation), distributed Flex-server roles, least-privilege accounts, and dedicated servers per function for high assurance. **Ext. tools:** Role/server separation review.	Roles/applications partitioned to contain compromise.	

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 6.1	Audit log accessibility	Confirm audit/alarms are readable/exportable and forwarded to the SIEM for continuous monitoring; the BMS zone is monitored (IDS). **Ext. tools:** Syslog/SIEM forwarding; passive OT IDS.	Events accessible/exportable and monitored in near-real-time.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 6.2	Continuous monitoring	Confirm continuous monitoring — events forwarded to and monitored by a SIEM/OT-IDS in near-real-time. **Steps:** for this product this is assessed with the same evidence as **SR/CR 6.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Continuous monitoring verified individually.	

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 7.1	Denial-of-service protection	Confirm DoS resilience: host firewall + distributed-system redundancy, only required services exposed, connection limits; a flood does not deny BMS operation. **Ext. tools:** Firewall review; Nmap; load test (ISOLATED).	Attack surface minimized; BMS resists DoS (redundancy where used).	
SR/CR 7.2	Resource management	Confirm host/DB resource controls (CPU/memory/disk limits, SQL sizing, history rotation) so one process cannot starve the BMS server. **Ext. tools:** Performance Monitor; SQL/history config.	Resources bounded; no single-process exhaustion.	
SR/CR 7.3	Control system backup	Confirm the Desigo CC project, history, and server image are backed up (versioned, offline) and restore is tested; distributed redundancy validated. **Ext. tools:** Backup review; restore test (lab).	Backups current and recovery validated.	
SR/CR 7.4	Control system recovery & reconstitution	Confirm recovery/reconstitution — a restore to a known-good state is tested. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.3** above (shared steps); confirm this requirement individually and adjudicate it separately.	Control system recovery & reconstitution verified individually.	
SR 7.5	Emergency Power	**N/A.** Emergency/backup power is provided at the facility/UPS level, not the device; confirm the device retains its security state across a power transfer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 7.6	Network & security configuration settings	Confirm hardening: unused modules/Web disabled, host services minimized per the Siemens security guideline, BACnet/OPC endpoints restricted. **Ext. tools:** Service/module review; Nmap.	Least functionality; unused services disabled per baseline.	
SR/CR 7.7	Least functionality	Confirm least functionality — unused services/ports/protocols are disabled. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.6** above (shared steps); confirm this requirement individually and adjudicate it separately.	Least functionality verified individually.	
SR/CR 7.8	Component inventory	Confirm Desigo CC version, patches, modules, and host are inventoried so vulnerabilities track against Siemens ProductCERT advisories. **Ext. tools:** ReadOnlyEnum; version/patch inventory.	Accurate software/version inventory maintained.	

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
Desigo CC System Management	Identity, scopes & audit review (FR1, 2.1, 2.8)	Read users/groups/scopes, application rights, and the audit trail; confirm least privilege.	Read/authorized copy.
SCAP/STIG (host)	Host hardening verification (3.3, 7.6)	Scan the hosting Windows Server against STIG/CIS; reference the Windows cheat sheet.	Authorized.
Nmap / ReadOnlyEnum	Exposed-service & zone enumeration (1.13, 5.x, 7.6, 7.8)	Enumerate Web/BACnet/SC/OPC UA/SQL from each zone; confirm only required services reachable.	Read-only; authorized.
testssl.sh / OPC UA client	TLS, BACnet/SC & OPC UA strength (1.8, 1.9, 4.3)	Check TLS/cipher strength and OPC UA/BACnet/SC security policy.	Non-intrusive.

Tool / method	Verifies	How to use — steps / example	Constraints
Wireshark	Comms integrity review (3.1, 3.8)	Confirm BACnet/SC/OPC UA channels are encrypted+authenticated; cleartext BACnet contained to the zone.	Passive capture.
Syslog listener + SIEM	Event forwarding & monitoring (2.8-2.10, 6.x)	Confirm audit/security events reach the SIEM; trigger a test event.	Coordinate with SIEM team.

Controlled - Project Use · Independent Assurance Services · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.